

Artifact 16 — Compliance & Privacy Audit

Strategy · Stage 3 · Compliance & Risk Gate

DOCUMENT DETAILS

Project	Home-Care-AI	Stage	Strategy → Stage 3 (Compliance & Risk Gate)
Date	2026-03-27	Auditor Role	Data Privacy Officer & Healthcare Compliance Lead
Methodology	Data Inventory Map + Inference Privacy Risk Table + High-Risk Compound Combination Analysis + APP-native Mitigation Requirements		
Regulatory	Australian Privacy Act 1988 (APP) — operative. HIPAA-grade security architecture applied as design floor. Anti-discrimination legislation (relevant to P-2 scoring — SC-01 from Artifact 10).		
Feeds into	agentic-logic-spec NFRs (HS-STRAT-02); create-prd Constraints section (CLAUDE.md Article IV Rule 7)		

CLAUDE.md Article IV Rule 4 — Compliance Gate: Zero **CRITICAL** findings may remain open when entering Stage 4 (Go-to-Market Architecture). An open **CRITICAL** finding is an illegal data flow. This audit identifies four **CRITICAL** findings. Stage 4 cannot begin until **CRIT-01** through **CRIT-04** are resolved.

CLAUDE.md Article IV Inference Risk Instruction: Every AI Intervention Opportunity from Artifact 15 has been evaluated for indirect health inference. All four L3 Escalator actions (**ACT-C-01**, **ACT-C-02**, **ACT-P-01**, **ACT-F-01**) are candidates for the High-Risk Compound Combination check. The "Data Required" column from Artifact 15 §3 feeds directly into the Data Inventory Map rows below.

Table of Contents

Table of Contents	2
1. Compliance Risk Score	4
2. Data Inventory Map	5
3. Inference Privacy Risk Table	8
4. High-Risk Compound Combinations	10
CC-1 (NEW — This Audit) — P-3 + P-4 + P-5: Vulnerability Profile Compound	10
CC-2 (NEW — This Audit) — Client Notification Phrasing + P-7: Indirect Carer Identity Disclosure to Client	10
CC-3 (From Artifact 10 G-CC-3) — A-4 + P-11 in External Surface	10
CC-4 (From Artifact 10 G-CC-4) — S-4 + P-2: Discriminatory Assignment Risk	11
CC-5 (From Artifact 10 G-CC-5) — P-9 Free-Text in Any Schema	11
CC-6 (From Artifact 10 G-CC-6) — A-2 + Carer Notification Payload	11
CC-7 (From Artifact 10 G-CC-8) — WhatsApp Channel + Yellow/Red Data	12
5. Mitigation Requirements	13
CRITICAL — Block Stage 4 Entry Until Resolved	13
HIGH — Must Resolve Before GA; Limited Beta with Explicit Consent Acceptable	13
MEDIUM — Resolve Within 90 Days; Document Risk Acceptance if Deferred	14
LOW — Best-Effort; Acceptable with Standard Privacy Notice	15
6. Compliance Risk Score — Per Data Flow	16
7. Audit Log Template — APP-Aligned Extension of CLAUDE.md Article IX Schema	17
8. Compliance Gate Assessment — Stage 4 Entry Criteria	19
9. Handshake Table — HS-STRAT-02	20
10. Action Items	21

1. Compliance Risk Score

Overall Score: HIGH (7.8/10) — bordering CRITICAL

Rationale: The product collects and discloses *sensitive information* under the Australian Privacy Act 1988 (health information, including cognitive vulnerability indicators and care preference data) through an external third-party channel (WhatsApp/Meta — US-based) that currently lacks a confirmed APP 8 cross-border disclosure framework. Four data flows are CRITICAL-rated. The product is architecturally sound — the Agentic Safety Discovery (Artifact 10) has pre-empted most compound combination risks — but legal instrument gaps (APP 8 WhatsApp agreement, E-1 anti-discrimination sign-off, DPIA for compound sensitive data profile, prompt injection safeguards) must be closed before any data collection begins.

Score breakdown by domain

Domain	Score	Driver
Data collection (SPP fields)	7/10	P-2/P-3/P-4/P-5 are sensitive information under APP 3.3; consent mechanism not yet confirmed
Third-party disclosure (WhatsApp)	9/10	APP 8 cross-border disclosure to Meta/US — no confirmed legal basis
AI inference pipeline	8/10	Compound sensitive profile (P-3+P-4+P-5) creates near-complete vulnerability profile; DPIA required
Access controls & audit logging	4/10	Schema pre-specified (CLAUDE.md Article IX); architecture sound; not yet implemented
Discrimination risk (P-2 scoring)	9/10	Anti-discrimination legislation exposure; E-1 sign-off absent

2. Data Inventory Map

Source: Artifact 15 §3 "Data Required" columns (Steps 1–10) + Artifact 10 §2 Action Inventory. Every data point the system collects, computes, or discloses.

Australian Privacy Act classification: "Sensitive information" (s 6 Privacy Act 1988) includes health information, which means information or opinion about a person's health, disability, or care services received. Sensitive information requires explicit consent for collection (APP 3.3) and has stricter use/disclosure limits (APP 6.1). All sensitive information fields are marked SI.

ID	Data Point	Type	APP Classification	Risk Score	Lawful Basis	De-identification Strategy	External Disclosure?
S-1a	Carer full name	PII	Personal information	4	Contract (employment/engagement)	First name only in external payloads (ACT-C-01, ACT-C-02)	Carer only (self-referential)
S-1b	Carer phone number	PII	Personal information	5	Contract (employment/engagement)	Not in logs; tokenized reference only; used for WhatsApp send — APP 8 concern	WhatsApp/SMS channel (APP 8 trigger)
S-1c	Carer qualifications + credential expiry	PII	Personal information	4	Contract; regulatory compliance (care industry)	Stored server-side; pass/fail gate only surfaced in UI	Coordinator display only
S-2	Carer self-reported postcode	PII	Personal information	3	Voluntary collection for care delivery	Aggregate proximity score only; raw postcode not disclosed in any payload	No external disclosure
S-3	Carer-to-client proximity score (computed)	Derived	Operational data	2	Legitimate interest (care delivery optimisation)	Score only (km); raw postcode not in output	No
S-4	Carer-client assignment history (past visits)	PII + SI	Health service utilization — sensitive information	6	Care delivery; legitimate interest	Pseudonymised client UUIDs only; no client names. G-CC-4: never combined with P-2 in scoring without E-1 sign-off.	Coordinator display only
P-2	Client gender preference for carer	SI	Sensitive information — potentially health-related	7	Explicit consent required (APP 3.3)	Advisory display to coordinator only. G-CC-4: must NOT enter match scoring without E-1 anti-discrimination legal sign-off. Never in carer/client/family notification.	Coordinator UI only (never external)
P-3	Client familiarity threshold ("known carers only")	SI	Sensitive information — disability/cognitive vulnerability indicator	8	Explicit consent required (APP 3.3)	Structured category (0=any, 1=preferred, 2=known-acceptable, 3=known-only). Affects briefing framing. Never in external payload as a field.	Informs briefing tone (implicit only)
P-4	Cognitive or special care flags	SI	Health information — APP s6	9	Explicit consent required; care purpose exemption (APP 3.4(b))	Coordinator display only. NEVER in any external notification payload. Affects SPP matching logic internally.	BLOCKED from all external payloads

ID	Data Point	Type	APP Classification	Risk Score	Lawful Basis	De-identification Strategy	External Disclosure?
P-5	Personal sensitivities (structured, max 100 chars)	SI	Health information sensitive information /	7	Explicit consent required; care purpose	Structured fields only (no free text in v1). Disclosed to confirmed carer via ACT-C-02 for visit preparation. Lawful basis for carer disclosure must be documented.	Confirmed carer only (ACT-C-02)
P-6	Entry protocol (structured dropdown label)	PII	Personal information (behavioural)	4	Care delivery; legitimate interest	Label only (e.g., "Knock and wait — client takes a moment"). Reason/history not stored.	Confirmed carer only (ACT-C-02)
P-7	Carer visit count per client (familiarity history)	SI	Health service utilization — sensitive information	6	Care delivery; legitimate interest	Count + last_visit_date only (v1). No outcome data (P-8 binary only per G-DS-03).	Surfaced as "2 prior visits" trust signal (coordinator + client notification phrasing)
P-8	Binary familiarity flag per carer-client pair	SI	Derived from P-7; health service utilization	5	Care delivery	Binary (visited/not visited). Not individually linkable to dates in external output.	Inform notification phrasing ("who has visited you before")
P-9	Free-text notes (SPP narrative field)	SI	Health information uncontrolled —	CRITICAL	BLOCKED in v1	G-CC-5: P-9 must not exist in v1 schema. Any free-text field is an uncontrolled PHI risk — it will inevitably contain diagnoses, medication names, and behavioural observations. Schema must enforce absence.	BLOCKED
P-10	SPP completeness score	Operational	Non-personal aggregate	2	Legitimate interest	Aggregate percentage; no individual field content. Coordinator + agency owner dashboard only.	Agency owner dashboard
P-11a	Client suburb (pre-assignment proximity)	PII	Personal information (location partial) —	4	Care delivery	Suburb only before coordinator_approved. Full address withheld.	Carer notification (suburb only per CC-8)
P-11b	Client full address	PII	Personal information (location)	6	Care delivery (need-to-know, post-approval)	Released only after coordinator_approved = true. To confirmed carer only. Never transmitted via WhatsApp (CC-8 guard).	SMS/in-app to confirmed carer only
A-1	Match score (numeric composite)	Derived	Operational data	3	Legitimate interest (transparency to coordinator)	Score only. Allowed in carer notification payload (CC-8 compliant).	Coordinator + carer notification (score only)

ID	Data Point	Type	APP Classification	Risk Score	Lawful Basis	De-identification Strategy	External Disclosure?
A-2	Match explanation (SPP tags driving score)	Derived — references SI	Sensitive information (compound)	7	Internal — coordinator session only	G-CC-6 + G-DS-04: NEVER in carer, client, or family notification. Coordinator session scoped. Session-cleared on logout.	BLOCKED from all external payloads
A-3	Compliance alerts (credential expiry, care plan overdue)	Operational PII	Personal information (staff credential)	4	Regulatory compliance; care safety	Coordinator-facing only. G-E3-04: never in client or family UI.	BLOCKED from client/family payloads
A-4	Continuity score (cross-visit care relationship quality)	Derived SI	Sensitive information (health service pattern)	6	Legitimate interest	Coordinator display only. G-CC-3: never combined with P-11 (address) in any external output.	BLOCKED from all external payloads
F-1	Client notification channel (SMS number / app enrolment)	PII	Personal information	4	Enrolled at intake; care delivery	Notification use only; not used for profiling or secondary purposes.	Carrier/SMS gateway only
F-2	Family contact channel (SMS/email/app preference)	PII (third party)	Personal information (family member)	5	Consent from client or family at intake (must cover automated scheduling notifications)	Notification use only. E-3 gate controls timing.	SMS/email carrier only
AUD-1	Coordinator ID + approval decision + timestamp	PII (staff)	Personal information	4	Legal obligation; audit compliance	Pseudonymised UUID in immutable log. Human-readable name in coordinator UI only.	Audit log (access-controlled)
AUD-2	Full audit log entry (all HIPAA AuditLogEntry fields)	PII + SI aggregate	Sensitive information (aggregate)	7	Legal obligation; regulatory compliance; 7-year retention	Append-only; hash-chained; no plaintext PHI in log fields (patient_id = UUID). HIPAA-grade architecture per CLAUDE.md Article IX.	Audit report (agency owner + regulatory body on request)

Highest-risk data points requiring immediate action: P-2 (7), P-3 (8), P-4 (9), P-5 (7), P-9 (CRITICAL — blocked), A-2 (7), AUD-2 (7), WhatsApp channel for S-1b (APP 8 — CRITICAL).

3. Inference Privacy Risk Table

Per the skill instruction: "For every AI Intervention Opportunity from the journey map, evaluate whether it creates an indirect health inference. Level 3 Interventions are automatically candidates for the High-Risk Compound Combination check."

Attack Vector	Present?	Severity	AI Intervention Affected	Safeguard Required	Status
Prompt Injection	YES — if LLM used for SPP summarisation, match explanation generation, or briefing composition	CRITICAL	ACT-V-07 (match explanation), ACT-C-02 (carer briefing), any LLM-assisted SPP field	Input sanitisation layer before any user input concatenated into system prompt. PHI pattern scanner on all LLM outputs (regex: names, addresses, DOBs, health terms). Prompt boundary enforcement (system prompt vs. user input separation). Red-team injection testing before beta.	OPEN — blocks any LLM feature
Training Data Leakage	POTENTIAL — if SPP data or carer-client history is used in future fine-tuning	HIGH	Any future ML/LLM model trained on Home-Care-AI data	No real SPP/client data in any training dataset. Synthetic data only (Artifact 17 / synthetic-phi-generator). Differential privacy if any aggregate data used. Model card must document training data provenance. Policy required before any ML feature development.	OPEN — pre-emptive policy required
RAG Cross-Patient PHI Contamination	POTENTIAL (v2 risk) — if SPP fields are indexed into a vector store for semantic retrieval	CRITICAL	ACT-V-07 (match explanation retrieval), ACT-C-02 (briefing assembly)	Per-client namespace isolation in vector store. client_id as mandatory metadata filter on every retrieval query. Unit test asserting Client B's SPP chunks never appear in Client A's context window. Must be architecturally specified in agentic-logic-spec before any RAG feature is built, even in development.	OPEN — architectural pre-specification required
Cross-Session Memory Leakage	YES — coordinator session data (shortlists viewed, candidates reviewed) must not persist	HIGH	ACT-A-01/A-02 (shortlist + approval), ACT-V-06/V-07 (match display)	Session-scoped memory with automatic expiry on logout/timeout. Per-session encryption keys. Explicit memory clearing on session end. Coordinator must not see prior session's shortlist candidates on reopening the app.	OPEN
Health Inference via Behavioural Pattern	POTENTIAL — P-3 (familiarity threshold) combined with P-5 (sensitivities) creates a dementia/cognitive vulnerability inference	HIGH	ACT-V-02/V-04 (match algorithm), ACT-C-02 (briefing)	Structured field constraints (dropdowns, not free text) limit inference surface. P-4 (explicit cognitive flag) requires explicit consent before collection. Compound DPIA required (see §4).	OPEN — DPIA required

Attack Vector	Present?	Severity	AI Intervention Affected	Safeguard Required	Status
Coordinator Override Pattern as Inference	POTENTIAL — systematic coordinator overrides of AI ranking (ACT-A-04) may reveal aggregate health signals about client populations	MEDIUM	ACT-A-04 (override logging)	Override logs store coordinator_id + reason_category only (no client_id in override analytics). Aggregate analytics are de-identified before any reporting.	OPEN — architecture constraint

4. High-Risk Compound Combinations

Source: Artifact 10 §5A guards G-CC-3 through G-CC-8, plus two new combinations identified during this audit. Each must appear in the PRD's Constraints section per CLAUDE.md Article IV Rule 7.

CC-1 (NEW — This Audit) — P-3 + P-4 + P-5: Vulnerability Profile Compound

	Detail
Fields combined	P-3 (familiarity threshold — cognitive vulnerability indicator) + P-4 (cognitive/special care flags) + P-5 (personal sensitivities — structured)
Inferred health signal	Near-complete psychological and cognitive profile of a vulnerable senior: "This person has cognitive decline, is highly distressed by unfamiliar people, and has specific sensory or behavioural sensitivities." Effectively a dementia diagnosis inference without a medical record.
Risk level	CRITICAL
Regulatory exposure	APP 3.3: collection of sensitive information (health information) without explicit, informed consent for the combined purpose. DPIA mandatory before data collection begins.
Required safeguard	(1) Explicit consent for each field category at intake (separate consent events, not bundled into general T&Cs). (2) DPIA conducted before collection of P-3/P-4 combination is enabled. (3) P-4 gated behind a named clinical reviewer (not populated by coordinator without formal assessment). (4) Combined profile never transmitted externally in any form.
Handshake	Must appear in agentic-logic-spec as an explicit IF-THEN guard: IF (P-3 AND P-4 AND P-5) surfaced together in any external payload THEN block send + alert coordinator.

CC-2 (NEW — This Audit) — Client Notification Phrasing + P-7: Indirect Carer Identity Disclosure to Client

	Detail
Fields combined	Client notification (ACT-P-01): "Your visit today will be with [carer first name], who has visited you before" + P-7 (visit history confirming prior visits)
Inferred health signal	Confirms to the client (and any observer of their phone) that a care relationship exists. If the client is cognitively impaired (P-3/P-4), they may not remember the prior visit — the message may cause confusion rather than reassurance for high-P-3 clients.
Risk level	MEDIUM
Required safeguard	(1) Notification phrasing must be P-3-aware: for P-3 = "known only" clients, the message should not rely on the client remembering. Adjust to: "Your carer today is David, who has visited you several times. Angela organised this." (2) For P-3 = "any carer" clients, the current phrasing is appropriate. Design must branch on P-3 value.
Handshake	agentic-logic-spec notification phrasing logic must branch on client.familiarity_threshold value.

CC-3 (From Artifact 10 G-CC-3) — A-4 + P-11 in External Surface

	Detail
Fields combined	Continuity score (A-4) + client address (P-11) appearing together in any family-facing or external output
Inferred health signal	"This specific address has a high/low care continuity score" — implies health or behavioural instability at a residential address.
Risk level	HIGH
Required safeguard	Structural assertion: these two fields never appear in the same external response payload. Coordinator-only.
Status	Specified in Artifact 10. Must transfer to agentic-logic-spec as named guard.

CC-4 (From Artifact 10 G-CC-4) — S-4 + P-2: Discriminatory Assignment Risk

	Detail
Fields combined	Carer-client assignment history (S-4) + client gender preference (P-2) as active match scoring inputs
Inferred health signal	Not a health inference — a discrimination liability. Scoring on gender preference may violate anti-discrimination legislation (Sex Discrimination Act 1984 (Cth) or state equivalents).
Risk level	CRITICAL — blocks matching engine build
Required safeguard	E-1 legal sign-off (anti-discrimination opinion) must be obtained before P-2 enters any scoring algorithm. Until signed off: P-2 is advisory display only ("Client preference: Female — not scored"). S-4 may remain a scoring input.
Status	SC-01 from Artifact 10 — OPEN.

CC-5 (From Artifact 10 G-CC-5) — P-9 Free-Text in Any Schema

	Detail
Field	P-9: free-text notes field in the SPP
Inferred health signal	Inevitably will contain: diagnoses, medication names, incident descriptions, behavioural observations — uncontrolled PHI with no field-level constraints.
Risk level	CRITICAL
Required safeguard	P-9 must not exist in the v1 data schema. Schema validation must enforce field-level absence. Any attempt to add a free-text field to the SPP is a CRITICAL finding.
Status	G-CC-5 from Artifact 10 — OPEN (must be confirmed absent in data model spec).

CC-6 (From Artifact 10 G-CC-6) — A-2 + Carer Notification Payload

	Detail
Fields combined	Match explanation (A-2: which SPP tags drove the score) + any carer-facing notification

Inferred health signal	Discloses to the carer <i>why</i> they were selected — which means disclosing the client's SPP fields (e.g., "Selected because: female preference match + 2 prior visits + client has entry anxiety"). This reveals P-2 and P-5 to the carer without a separate consent event from the client.
Risk level	HIGH — APP disclosure breach
Required safeguard	Pre-send assertion: <code>match_explanation_in_payload = false AND gender_preference_in_payload = false</code> before ACT-C-02 executes. If either fails → block send + alert coordinator.
Status	SC-04 from Artifact 10 — OPEN.

CC-7 (From Artifact 10 G-CC-8) — WhatsApp Channel + Yellow/Red Data

	Detail
Fields combined	WhatsApp as delivery channel (Meta — US-based servers) + any data classified as Yellow or Red zone
Inferred health signal	Indirect: if P-5/P-3 fields appear in WhatsApp payload, they are transmitted to a US company under Meta's terms of service. Even Green-only data in a WhatsApp message is subject to Meta's data processing, which may not comply with APP 8 cross-border disclosure requirements.
Risk level	CRITICAL — APP 8 breach
Required safeguard	(1) Immediate: legal review of Meta Business API terms against APP 8 requirements. (2) Pre-send assertion: all WhatsApp payload fields enumerated as Green zone (<code>carer_first_name</code> , <code>visit_time</code> , <code>client_suburb</code> , <code>match_score</code> only). (3) Fallback channel (SMS) as default until APP 8 framework confirmed. (4) Carers must consent to receiving WhatsApp messages for work purposes.
Status	SC-02 from Artifact 10 — OPEN.

5. Mitigation Requirements

Ordered by risk priority. CLAUDE.md Article IV Rule 4: zero CRITICAL findings before Stage 4.

CRITICAL — Block Stage 4 Entry Until Resolved

ID	Finding	Affected Action	Required Resolution	Owner
CRIT-01	APP 8 — WhatsApp cross-border disclosure framework absent. Meta (WhatsApp) processes data on US servers. Transmitting carer PII or client suburb via WhatsApp without a confirmed APP 8 legal basis is an unlawful cross-border disclosure.	ACT-C-01 (carer assignment), ACT-C-02 (briefing)	(1) Legal review of Meta Business API Data Processing Agreement against APP 8. (2) Either: obtain a signed APP 8 agreement, or confirm Meta satisfies "substantially similar" protection standard, or switch to SMS as default channel until resolved. (3) Explicit consent from carers for WhatsApp work communications.	Privacy Counsel + Legal
CRIT-02	Prompt injection safeguard absent. Any LLM-assisted feature (match explanation generation, briefing composition, SPP summarisation) that receives coordinator or carer input is vulnerable to injection attacks that could extract SPP/PHI from the system prompt context.	ACT-V-07 (match explanation), ACT-C-02 (briefing), any LLM feature	(1) Input validation layer before user input concatenation into any LLM prompt. (2) Output PHI scanner (regex pattern matching for names, DOBs, health terms) on all LLM completions before display or delivery. (3) Prompt boundary enforcement architecture specified in agentic-logic-spec. (4) Red-team injection testing before beta launch.	Engineer + Security
CRIT-03	P-2 in match scoring — anti-discrimination legal sign-off absent (E-1). Scoring client gender preference as an active match weight may breach Sex Discrimination Act 1984 (Cth) and/or state equivalents.	ACT-V-02/V-04 (match algorithm)	E-1 legal sign-off obtained before matching engine build begins. Until signed off: P-2 is collected and stored but excluded from scoring, displayed to coordinator as advisory only.	Legal Counsel (SC-01 from Artifact 10)
CRIT-04	P-9 (free-text SPP field) schema exclusion not confirmed. If P-9 is permitted in the v1 data model in any form (even as an empty field), it will inevitably be populated with uncontrolled health information that has no field-level privacy constraints.	All data collection	Data model specification must explicitly exclude P-9. Schema validation must enforce field-level absence. Confirmed in writing by engineering lead before data model is finalised.	Engineer (SC-05 from Artifact 10)

HIGH — Must Resolve Before GA; Limited Beta with Explicit Consent Acceptable

ID	Finding	Affected Action	Required Resolution	Owner
HIGH-01	Consent framework for sensitive information (P-2, P-3, P-4, P-5) not specified. Under APP 3.3, collecting sensitive information (including health information) requires explicit consent. Current intake process is unspecified.	SPP population (ACT-S-03)	(1) Informed consent mechanism at client intake — separate consent events for each sensitive information category. (2) P-4 (cognitive flags) gated behind named clinical reviewer sign-off. (3) Consent record stored with timestamp and consent version; referenced in audit log as consent_record_id.	Product + Legal
HIGH-02	Lawful basis for disclosing P-5/P-6 to carer (ACT-C-02) not formally documented. Briefing the carer with structured SPP fields is a disclosure of sensitive information to a third party. APP 6.1 restricts use/disclosure of sensitive information to the purpose of collection unless another exception applies.	ACT-C-02 (carer briefing)	(1) Document lawful basis (likely: health services delivery purpose, APP 3.4(b) care purpose exemption + carer's duty of care). (2) Carer engagement contract must include data handling clause covering SPP field disclosure. (3) Confirmed in BAA-equivalent with carer workforce.	Legal + HR

ID	Finding	Affected Action	Required Resolution	Owner
HIGH-03	DPIA required for compound sensitive profile (CC-1: P-3 + P-4 + P-5). The combination of familiarity threshold + cognitive flags + personal sensitivities creates a near-complete vulnerability profile of a senior. This is high-risk processing under Australian Privacy Act and best-practice DPIA triggers.	SPP population; ACT-V-02 (match algorithm)	(1) Conduct DPIA before any collection of P-3/P-4 combination is enabled. (2) DPIA must include: data flow map, risk assessment, mitigation measures, sign-off by Privacy Officer. (3) Document DPIA outcome in a Privacy Notice accessible at intake.	Privacy Officer
HIGH-04	Google Maps API cross-border data processing (APP 8 — proximity computation, S-3). Transmitting carer postcode data to Google's APIs involves cross-border disclosure to a US company. While Google's API terms include data processing agreements, APP 8 compliance must be confirmed.	ACT-V-03 (proximity score)	(1) Review Google Cloud / Maps API DPA against APP 8 requirements. (2) If sufficient: document confirmation. (3) If insufficient: switch to local geocoding library or Australian-hosted service. (4) Only postcode data transmitted — never client address or PII other than postcode.	Engineer + Legal
HIGH-05	RAG vector store cross-client contamination risk (architectural pre-specification). If any future feature stores SPP fields in a vector database (semantic search, auto-briefing), per-client namespace isolation must be architecturally specified before the first line of that feature is written.	ACT-V-07 (future), ACT-C-02 (future)	(1) agentic-logic-spec must include RAG architecture constraints: per-client namespace mandatory, <code>client_id</code> metadata filter on every query. (2) Unit test specification: assert Client B's SPP chunks cannot appear in Client A's retrieval context. (3) This specification is required even if no RAG feature is in v1 — it must be the constraint that any future engineer sees first.	Architect + Engineer
HIGH-06	Cross-session coordinator memory isolation not specified. Coordinator session data (shortlists reviewed, candidates considered) must not persist across sessions. A coordinator reviewing candidates at 6:30 AM must not see stale shortlist data when they reopen the app at 9:00 AM for a different incident.	ACT-A-01/A-02 (shortlist), ACT-V-06/V-07 (match display)	(1) Session-scoped memory with automatic expiry on logout or timeout. (2) Per-session encryption keys. (3) Explicit session clear on logout. (4) Specify in agentic-logic-spec as a named NFR.	Engineer
HIGH-07	CC-6 guard not yet implemented (match explanation in briefing payload). Disclosed in Artifact 10 SC-04. Must be in agentic-logic-spec as an assertion — not as a comment or a manual process.	ACT-C-02 (carer briefing)	Pre-send assertion in code: <code>assert match_explanation_in_payload == False AND assert gender_preference_in_payload == False</code> . If either assertion fails: block send, log <code>CC6_GUARD_BLOCKED</code> , alert coordinator.	Engineer (SC-04 from Artifact 10)
HIGH-08	E-3 structural gate not yet in code (coordinator_approved AND client_notified prerequisite for ACT-F-01). Disclosed in Artifact 10 SC-03. This is the Arthur Kovacs failure-prevention gate.	ACT-F-01 (family notification)	Named boolean gate in every notification function signature: <code>send_family_notification(coordinator_approved: bool, client_notified: bool)</code> . If either = false: block + log <code>E3_GATE_BLOCKED</code> + alert coordinator.	Engineer (SC-03 from Artifact 10)

MEDIUM — Resolve Within 90 Days; Document Risk Acceptance if Deferred

ID	Finding	Affected Action	Required Resolution
MED-01	APP 5 notification at intake — collection notice not specified. Clients and families must be notified at intake of: what data is collected, for what purpose, who it may be disclosed to, and how to access/correct it.	All data collection	Intake privacy notice drafted. Must cover: SPP fields (purpose = care quality + matching), notification channels (purpose = scheduling coordination), and any third-party disclosures (WhatsApp, Google Maps).

ID	Finding	Affected Action	Required Resolution
MED-02	7-year audit log retention infrastructure not specified. HIPAA-grade floor requires append-only storage with 7-year minimum retention (CLAUDE.md Article VII). WORM-compliant store must be in infrastructure spec.	ACT-AUD-01 (all audit writes)	Infrastructure spec must name immutable store: AWS S3 Object Lock, Azure Immutable Blob, or equivalent. No application role may have DELETE or UPDATE access to audit tables. Confirm before GA.
MED-03	Family contact consent scope (F-2) may not cover automated scheduling notifications. A family contact's phone number collected for emergency contact may not have consent covering automated "replacement carer arranged" SMS messages.	ACT-F-01 (family notification)	(1) Confirm consent at intake covers scheduling notification use. (2) If in doubt: obtain fresh consent event for this notification category. (3) Opt-out mechanism required (APP 7 direct marketing analogy).
MED-04	Training data provenance policy absent. No policy currently prevents real SPP/client data from being used in future model fine-tuning.	Future ML/LLM development	Written policy: "No real client data (SPP, visit records, audit logs) in any model training dataset. Synthetic data only (synthetic-phi-generator output). Differential privacy required for any aggregate statistics." Policy signed by product and engineering leads before any ML feature sprint begins.
MED-05	A-2 (match explanation) session-isolation not confirmed. Match explanation references sensitive SPP fields. If the coordinator logs out and the session is not cleared, A-2 data may be readable in browser cache or local storage.	ACT-V-07 (match explanation display)	(1) A-2 data never written to browser local storage or cache. (2) Session-cleared on logout. (3) Not included in any audit log display accessible to external parties.
MED-06	P-7/P-8 retention period not defined. Visit history accumulates over time. Without a retention limit, the familiarity history becomes an indefinite record of every care interaction a senior has had — which has APP implications for purpose limitation.	ACT-P-02 (SPP update), ACT-S-01 (history pre-population)	Define explicit retention period for P-7 visit records (recommendation: rolling 24 months, sufficient for familiarity matching). Archive or de-identify older records. Document in Privacy Notice.

LOW — Best-Effort; Acceptable with Standard Privacy Notice

ID	Finding	Required Resolution
LOW-01	P-11 suburb → full address boundary not logged. The expansion from suburb (pre-approval) to full address (post-approval) is a material disclosure event. It should produce an audit log entry.	Add address_revealed_post_approval event to audit event type registry.
LOW-02	SPP field update notification to client. When a coordinator updates a client's SPP (ACT-S-03), the client has an APP 13 right to know their information has been corrected/updated.	Design a periodic SPP review notification to client/family ("Your care profile was updated on [date]"). Not a real-time notification — a monthly/quarterly digest is sufficient.
LOW-03	Carer opt-out from WhatsApp notifications (if WhatsApp confirmed as channel). Carers should be able to switch to SMS without being deprioritised in the matching algorithm.	Carer notification channel preference field in carer profile. Notification channel preference must not influence match score.

6. Compliance Risk Score — Per Data Flow

Summary for engineering handoff. Each data flow maps to a numbered mitigation requirement above.

Data Flow	Risk Score	Primary Finding	Mitigation
SPP collection at intake (P-2, P-3, P-4, P-5)	8/10	Sensitive information; consent not specified	CRIT-03 (P-2), HIGH-01 (consent), HIGH-03 (DPIA)
WhatsApp carer notification (ACT-C-01)	9/10	APP 8 cross-border disclosure	CRIT-01
Carer briefing dispatch (ACT-C-02)	8/10	P-5/P-6 disclosure; CC-6 guard; APP 6.1 lawful basis	HIGH-02, HIGH-07
Client SMS notification (ACT-P-01)	5/10	E-3 gate; phrasing accuracy; enrolment channel	HIGH-08, CC-2
Family SMS notification (ACT-F-01)	7/10	E-3 gate; consent scope; information accuracy	HIGH-08, MED-03
Match algorithm (ACT-V-02/V-04)	7/10	P-2 discrimination; compound profile DPIA	CRIT-03, HIGH-03
Match explanation display (ACT-V-07)	7/10	CC-6 guard; session isolation; LLM injection	CRIT-02, HIGH-05, HIGH-07
Proximity computation (ACT-V-03)	5/10	APP 8 (Google Maps); minimal PII transmitted	HIGH-04
Audit log writes (ACT-AUD-01)	4/10	7-year retention; immutable store	MED-02
LLM-assisted features (any)	9/10	Prompt injection; training data leakage	CRIT-02, MED-04

7. Audit Log Template — APP-Aligned Extension of CLAUDE.md Article IX Schema

The base schema is defined in CLAUDE.md Article IX (HIPAAAuditLogEntry). This section adds APP-specific fields and defines the event type extensions required for the scheduling workflow.

```
interface APPAuditLogEntry extends HIPAAAuditLogEntry {
  // APP-specific extensions (all non-nullable for compliance events)

  // APP 8 – Cross-border disclosure tracking
  cross_border_disclosure: boolean; // true if data transmitted to overseas recipient
  recipient_jurisdiction: string; // e.g., 'US' (Meta/WhatsApp), 'AU' (SMS gateway), 'INTERNAL'
  app8_basis: string; // 'Consent' | 'Substantially_Similar' | 'DPA_Confirmed' | 'NA'

  // Consent traceability
  consent_record_id: string; // UUID of the consent event authorising this data use; null if not applicable
  consent_version: string; // Version of privacy notice at time of consent

  // Data sensitivity (APP-aligned categories)
  data_sensitivity: string; // Extends CLAUDE.md: 'PHI' | 'PII' | 'SENSITIVE_INFO' | 'OPERATIONAL' | 'SYNTHETIC'
  // Note: 'SENSITIVE_INFO' = Australian Privacy Act sensitive information (health info, etc.)

  // Compound combination guard trace
  guard_id: string; // e.g., 'G-CC-6' | 'G-E3-01' | 'CC-1' | null
  guard_passed: boolean; // true = guard check passed; false = guard blocked the action
  guard_block_reason: string; // Populated if guard_passed = false; null otherwise
}
```

Fields required for each scheduling data access event

Field	Required For
timestamp (UTC, ISO 8601)	Every event
patient_id (UUID — never name)	Every event involving client data
user_id (UUID of coordinator or system actor)	Every approval, override, SPP update
event_type (from event registry below)	Every event
state_before + state_after	Every state transition
action_taken	Every L3 action
cross_border_disclosure + app8_basis	ACT-C-01 (WhatsApp), ACT-V-03 (Google Maps)
consent_record_id	Any disclosure of sensitive information (P-2 through P-8)
guard_id + guard_passed	Any action gated by a compound combination guard
entry_hash + previous_hash	Every entry (tamper detection)

Extended event type registry (additions to CLAUDE.md Article IX)

event_type	state_before	state_after
VACANCY_DETECTED	NORMAL	VACANCY_DETECTED
SHORTLIST_GENERATED	VACANCY_DETECTED	SHORTLIST_READY
HITL_REQUESTED	SHORTLIST_READY	HITL_PENDING
COORDINATOR_APPROVED	HITL_PENDING	COORDINATOR_APPROVED
COORDINATOR_OVERRIDE	HITL_PENDING	COORDINATOR_APPROVED
CARER_NOTIFIED	COORDINATOR_APPROVED	CARER_NOTIFIED
BRIEFING_SENT	CARER_NOTIFIED	BRIEFING_SENT

event_type	state_before	state_after
CLIENT_NOTIFIED	BRIEFING_SENT	CLIENT_NOTIFIED
FAMILY_NOTIFIED	CLIENT_NOTIFIED	FAMILY_NOTIFIED
E3_GATE_BLOCKED	CLIENT_NOTIFIED	FAMILY_GATE_BLOCKED
FAMILY_NOTIFICATION_SUPPRESSED	CLIENT_NOTIFIED	FAMILY_GATE_BLOCKED
CC6_GUARD_BLOCKED	COORDINATOR_APPROVED	BRIEFING_BLOCKED
CC8_FIELD_STRIPPED	(any)	(any)
CARER_DECLINED	CARER_NOTIFIED	HITL_PENDING
VACANCY_UNRESOLVED	HITL_DOUBLE_TIMEOUT	VACANCY_UNRESOLVED
SPP_FIELD_UPDATED	(any)	(any)
SPP_CONSENT_RECORDED	(any)	(any)
CONSENT_RECORD_CREATED	(any)	(any)
ASSIGNMENT_CANCELLED	(any)	(any)
FAMILIARITY_THRESHOLD_OVERRIDE	HITL_PENDING	COORDINATOR_APPROVED
COMPLIANCE_OVERRIDE_ACKNOWLEDGED	(any)	(any)
P9_COLLECTION_BLOCKED	(any)	(any)
CLIENT_NOTIFICATION_UNAVAILABLE	(any)	(any)
BRIEFING_DELIVERY_FAILED	CARER_NOTIFIED	(any)
CARER_NOTIFICATION_FAILED	COORDINATOR_APPROVED	(any)
DUPLICATE_VACANCY_SUPPRESSED	(any)	(any)

8. Compliance Gate Assessment — Stage 4 Entry Criteria

CLAUDE.md Article IV Rule 4: Zero CRITICAL findings before Stage 4 (Go-to-Market Architecture). This is the gate check.

Finding ID	Status	Gate Status
CRIT-01 (APP 8 / WhatsApp)	OPEN	■ BLOCKS STAGE 4
CRIT-02 (Prompt injection)	OPEN	■ BLOCKS STAGE 4
CRIT-03 (P-2 anti-discrimination / E-1 sign-off)	OPEN	■ BLOCKS STAGE 4
CRIT-04 (P-9 schema exclusion)	OPEN	■ BLOCKS STAGE 4

Current gate status: ■ STAGE 4 BLOCKED — 4 CRITICAL findings open.

Stage 4 (partnership-mapping) may proceed only after all four CRITICAL findings are resolved or formally accepted with a documented legal risk acceptance by an authorised officer. No CRITICAL finding may be carried into positioning-statement or ai-unit-economics.

Note: The HIGH findings (HIGH-01 through HIGH-08) are significant but do not block Stage 4 entry per the CLAUDE.md framework. They block GA and must be resolved before any feature ships. A limited beta with explicit participant consent is acceptable for HIGH-rated items.

9. Handshake Table — HS-STRAT-02

Per CLAUDE.md Article IV: "Mitigation Requirements → Non-Functional Requirements (NFRs) in the Logic Spec. Each NFR maps to: (a) a named threshold constant or state gate, and (b) a specific HIPAAuditLogEntry field. High-Risk Compound Combinations become explicit IF-THEN guards in pseudocode."

ID	From (This Audit)	To (Execution Plugin)	What Must Transfer
HS-STRAT-02a	CRIT-01 (APP 8 / WhatsApp)	agentic-logic-spec NFR-01	Named constant: WHATSAPP_APP8_CONFIRMED: bool = false (default). All ACT-C-01 WhatsApp sends must gate on this constant. Until true → fallback to SMS. Constant is toggled only by Privacy Officer sign-off event logged to audit log.
HS-STRAT-02b	CRIT-02 (Prompt injection)	agentic-logic-spec NFR-02	Architecture requirement: input sanitisation function sanitise_coordinator_input() must wrap every user input before LLM prompt concatenation. Output scanner scan_llm_output_for_phi() must run before every LLM completion is displayed or transmitted. Specified in pseudocode, not comments.
HS-STRAT-02c	CRIT-03 (P-2 / E-1 sign-off)	agentic-logic-spec NFR-03	Named constant: E1_LEGAL_SIGNOFF: bool = false (default). Match algorithm must gate P-2 scoring: IF E1_LEGAL_SIGNOFF == false THEN exclude P-2 from scoring_weights. Audit log: guard_id = 'G-CC-4'.
HS-STRAT-02d	CRIT-04 (P-9 schema)	agentic-logic-spec NFR-04	Schema validation rule: ASSERT 'free_text_notes' NOT IN spp_schema_fields. Must be enforced at data model layer, not application layer.
HS-STRAT-02e	HIGH-07 (CC-6 guard)	agentic-logic-spec guard	Before ACT-C-02: ASSERT match_explanation_in_payload == False AND gender_preference_in_payload == False. Audit: guard_id = 'G-CC-6', guard_passed = true/false.
HS-STRAT-02f	HIGH-08 (E-3 gate)	agentic-logic-spec guard	ACT-F-01 function signature: send_family_notification(coordinator_approved: bool, client_notified: bool). IF NOT (coordinator_approved AND client_notified): log event_type = 'E3_GATE_BLOCKED', guard_id = 'G-E3-01', guard_passed = false, alert coordinator, return without send.
HS-STRAT-02g	CC-1 compound (P-3+P-4+P-5)	agentic-logic-spec guard	Before any external payload assembly: ASSERT NOT (P3_present AND P4_present AND P5_present IN payload). This compound must never appear together in any outbound message. Audit: guard_id = 'CC-1'.
HS-STRAT-02h	HIGH-05 (RAG isolation)	agentic-logic-spec NFR-05	Architecture requirement: any vector store retrieval query must include filter = {'client_id': current_client_id} as a mandatory, non-optional metadata filter. Queries without this filter must raise a compile-time or runtime error, not silently proceed.
HS-STRAT-02i	MED-02 (7-year retention)	agentic-logic-spec NFR-06	Infrastructure NFR: audit log storage = append-only immutable store. Named constant: AUDIT_LOG_RETENTION_YEARS = 7. No DELETE or UPDATE permission granted to any application role.

10. Action Items

Due	Owner	Action	Priority
2026-03-28	Privacy Counsel	CRIT-01: Legal review of Meta Business API DPA against APP 8 requirements. Determine: (a) confirmed compliant, (b) insufficient — use SMS default, or (c) needs additional consent mechanism.	CRITICAL
2026-03-28	Legal Counsel	CRIT-03: Anti-discrimination opinion on P-2 in match scoring (E-1 sign-off). Already identified as SC-01 in Artifact 10.	CRITICAL
2026-03-28	Engineer	CRIT-04: Confirm P-9 (free-text SPP field) is absent from v1 data model schema. Document in writing.	CRITICAL
2026-03-29	Privacy Officer	HIGH-03: Initiate DPIA for compound sensitive profile (CC-1: P-3 + P-4 + P-5). Scope: data flow map, risk assessment, mitigation measures. Target completion: 2026-04-12.	HIGH
2026-03-29	Product Lead	HIGH-01: Draft informed consent mechanism for sensitive information collection at intake (P-2, P-3, P-4, P-5 as separate consent events).	HIGH
2026-03-29	Product Lead	HIGH-02: Document lawful basis for disclosing P-5/P-6 to carers via ACT-C-02. Confirm carer contract data handling clause scope.	HIGH
2026-03-31	Engineer + Architect	HIGH-05: Specify RAG vector store per-client namespace isolation in agentic-logic-spec as NFR-05 — before any RAG feature is built.	HIGH
2026-03-31	PM Lead	All HS-STRAT-02 handshakes (a-i) must be included in the agentic-logic-spec brief as explicit NFRs and named constants. These are not suggestions — they are compliance-required pseudocode gates.	HIGH
2026-04-01	Legal	HIGH-04: Review Google Maps API DPA against APP 8. Confirm only postcode transmitted (no PII, no client data).	HIGH
2026-04-15	Product + Legal	MED-01: Draft APP 5 intake privacy notice covering SPP fields, notification channels, and third-party disclosures.	MEDIUM
2026-04-15	Engineer	MED-02: Confirm immutable audit log infrastructure in architecture spec (AWS S3 Object Lock or Azure Immutable Blob).	MEDIUM
2026-04-15	Product	MED-03: Confirm family contact (F-2) consent scope covers automated scheduling notifications. Update intake form if not.	MEDIUM

Compliance gate note: This artifact is the mandatory input to agentic-logic-spec for all Non-Functional Requirements (HS-STRAT-02). Every CRITICAL and HIGH finding that remains open at the time agentic-logic-spec is written becomes a named NFR or a named constant in that document. A compliance finding that is not reflected in the logic spec is not mitigated — it is deferred to production, where it becomes a CRITICAL harness-audit-grader defect that blocks the merge gate (SD-01B).

Every High-Risk Compound Combination in §4 must appear verbatim in the PRD's Constraints section. This is the mechanism by which engineers cannot unknowingly build illegal data flows (CLAUDE.md Article IV Rule 7).